

Anhang A6 — EPK-Prozessbeschreibung ****Projekt:**** Zero-Trust-Sicherheitskonzept mit GitHub-Integration ****Prozess:**** Automatisierte Rechtevergabe (Self-Service → Genehmigung → Provisioning) ****Version:**** 1.0 | ****Datum:**** 09.07.2026 --- **## EPK:**

Rechtevergabe-Prozess (End-to-End) ``plantuml @startuml ' Ereignisgesteuerte Prozesskette (EPK) ' Funktionen (Rechtecke mit Rundung) :Start: Nutzer meldet Bedarf an; :Antrag stellen: Nutzer füllt Self-Service-Formular aus; :Validierung: System prüft Pflichtfelder & Policy; :Genehmigungsanfrage: System sendet Request an Vorgesetzten; :Genehmigung: Vorgesetzter prüft & entscheidet; :Provisioning: System ruft GitHub API auf (Team-Mitglied hinzufügen); :Audit-Log: Eintrag erstellen (Hash-Chain); :Benachrichtigung: E-Mail + GitHub Notification an Antragsteller; :Ende: Prozess abgeschlossen; ' Ereignisse (Sechsecke) event "Antrag eingereicht" as e1 event "Validierung OK" as e2 event "Validierung fehlgeschlagen" as e3 event "Genehmigung erteilt" as e4 event "Genehmigung abgelehnt" as e5 event "Provisioning erfolgreich" as e6 event "Provisioning fehlgeschlagen" as e7 ' Organisationseinheiten (Ellipsen) :Nutzer (Mitarbeiter); :System (Self-Service-Portal); :Vorgesetzter; :GitHub API; :Audit-System; :E-Mail-System; ' Logische Verknüpfungen (UND/ODER) ' Antragstellung e1 -> :Antrag stellen: :Nutzer (Mitarbeiter) -> e1 :System (Self-Service-Portal) -> :Antrag stellen: ' Validierung :Antrag stellen: -> e2 :Antrag stellen: -> e3 e2 -> :Validierung: e3 -> :Antrag stellen: # Rückkehr zur Korrektur ' Genehmigungsanfrage :Validierung: -> :Genehmigungsanfrage: :Genehmigungsanfrage: -> :Vorgesetzter: ' Genehmigungsentscheidung :Vorgesetzter -> e4 :Vorgesetzter -> e5 e4 -> :Genehmigung: e5 -> :Benachrichtigung: # Ablehnung → Info an Nutzer ' Provisioning :Genehmigung: -> :Provisioning: :Provisioning: -> :GitHub API: :GitHub API -> e6 :GitHub API -> e7 e6 -> :Audit-Log: e7 -> :Benachrichtigung: # Fehler → Info an Admin ' Audit-Log & Benachrichtigung :Audit-Log: -> :Audit-System: :Benachrichtigung: -> :E-Mail-System: :Benachrichtigung: -> :Nutzer (Mitarbeiter): @enduml `` --- **## EPK:**

Genehmigungs-Workflows (Detail) **### 1. Standard-Genehmigung (48h Frist) | Schritt |**

Funktion	Ereignis	Rolle	System
1 Antrag stellen	Antrag eingereicht	Nutzer	Self-Service
2 Validieren	Validierung OK/Fehler	System	Portal
3 Genehmigungsanfrage senden	Genehmigungsanfrage erstellt	System	E-Mail/GitHub
4 Genehmigen/Ablehnen	Genehmigung erteilt/abgelehnt	Vorgesetzter	E-Mail/Portal
5a Provisioning (bei Genehmigung)	Provisioning OK/Fehler	System	GitHub API
5b Ablehnungsnachricht	Ablehnung erteilt	System	E-Mail
6 Audit-Log schreiben	Log-Eintrag erstellt	System	Audit-DB
7 Benachrichtigen	Status-Update versendet	System	E-Mail/GitHub

2. Eskalation (nach 48h ohne Reaktion) | Schritt |

Funktion	Auslöser
E1 Erinnerung senden	24h ohne Reaktion
E2 Eskalation an IT-Admin	48h ohne Reaktion
E3 Admin entscheidet stellvertretend	Admin-Eingriff
E4 Prozess fortführen wie Standard	Ab E3 wie Schritt 4-7

--- **## Schnittstellen & Datentransfer | Übergang | Daten | Format |**

Übergang	Daten	Format
Nutzer → Portal	Antragsdaten (Rolle, Begründung, Ressource)	JSON (Formular)
Portal → Vorgesetzter	Genehmigungsrequest (Link, Antragsdetails)	E-Mail + GitHub Issue/Notification
Vorgesetzter → Portal	Entscheidung (approve/reject + Kommentar)	JSON (Callback)
Portal → GitHub API	Team-Membership (User, Team, Role)	REST (PATCH /

orgs/{org}/teams/{team}/memberships/{user}) | | Portal → Audit-Log | Log-Eintrag (User, Action, Resource, Result, Hash) | SQL INSERT | | Portal → E-Mail | Status-Nachricht (Template + Variablen) | SMTP (HTML/Text) | --- ## Rollen & Verantwortlichkeiten (RACI) | Aktivität | Nutzer | Vorgesetzter | System | IT-Admin | Auditor |
 |-----|-----|-----|-----|-----|-----| | Antrag stellen | **R** | I | A | I | I | I |
 Validieren | I | I | **R/A** | I | I | I | Genehmigen | I | **R/A** | C | I | I | I | Provisioning | I | I | I | **R/A** | C | I | I | Audit-Log | I | I | I | **R/A** | C | **R** | Eskalation | I | I | I | C | **R/A** | I | R =
 Responsible, A = Accountable, C = Consulted, I = Informed --- ## Risiken & Kontrollen im Prozess | Prozessschritt | Risiko | Kontrolle | |-----|-----|-----| | Antrag stellen | Falsche Rolle gewählt | Policy-Check (Pflichtfelder, Kompetenzmatrix) | | Validieren | Umgehung Validierung | Server-seitige Prüfung, Client-seitig nur UX | | Genehmigen | Vorgesetzter überlastet | 48h Eskalation, Stellvertretung konfigurierbar | | Provisioning | API-Fehler, Rate-Limit | Retry-Logic (3x), Dead-Letter-Queue, Alerting | | Audit-Log | Manipulation | Append-Only + Hash-Chain, DB-Trigger | | Benachrichtigung | E-Mail nicht zugestellt | Fallback: GitHub Notification, Retry | --- ## Kennzahlen (KPIs) für Prozess-Monitoring | KPI | Ziel | Messung | |-----|-----|-----| | **Durchlaufzeit** (Antrag → Berechtigung) | < 4 Stunden | Median, 95. Perzentil | | **Genehmigungsquote** | > 90 % | Genehmigt / (Genehmigt + Abgelehnt) | | **Eskalationsrate** | < 10 % | Eskalationen / Gesamtanträge | | **Fehlerquote Provisioning** | < 1 % | Fehlgeschlagen / Gesamt | | **Audit-Vollständigkeit** | 100 % | Log-Einträge / Prozessschritte | --- *Ende Anhang A6. Vgl. Kapitel 4.4 (Self-Service-Prozess) und 4.7 (Audit-Logging).*